

Research Portfolio

Evidence of Extraordinary Ability in Cybersecurity Research

Harshavardhan Malla

Independent Researcher

Cybersecurity — Vulnerability Management & Anomaly Detection

Portfolio date: May 31, 2026
Papers included: 4 original research papers
Venues targeted: IEEE, USENIX, ACM (peer-reviewed)
Data policy: All data synthetic and seeded;
no employer or production data used
Code policy: All code and results publicly released

Contents of This Portfolio:

1. **Exhibit A** — Paper 1: VulnPrio — Vulnerability Prioritization Benchmark
2. **Exhibit B** — Paper 2: CalibScore — Failure-Aware Calibration Gate
3. **Exhibit C** — Paper 3: HygieneBench — Cyber-Hygiene Anomaly Detection Benchmark
4. **Exhibit D** — Paper 4: HygienePrio — Hygiene-Augmented Exploit-Weighted Scorer

Each exhibit includes: (1) a one-page layperson significance statement; (2) a technical abstract; and (3) the full paper draft.

EXHIBIT A

Paper 1: **VulnPrio**

Context-Aware Vulnerability Prioritization for Government Endpoint Fleets: Integrating Exploit Intelligence, Asset Criticality, and Endpoint Telemetry

Harshavardhan Malla — Independent Researcher

Target venue: IEEE/USENIX Security Workshop on Measurement and Practice

Layperson Summary:

Government agencies receive thousands of new software vulnerability reports each month but can only fix a fraction of them before the next wave arrives. The standard approach — ranking by “severity score” (CVSS) — does not account for whether a vulnerability is actually being exploited in the wild, how critical the affected computer is, or how complex the patch is to apply. This paper introduces **VulnPrio**, a mathematical framework that combines seven signals (exploit probability, known exploitation status, severity, asset criticality, network exposure, urgency, and remediation difficulty) into a single priority score, and embeds that score in a scheduling system that automatically handles regulatory deadlines and records every decision in a tamper-evident log.

The key finding is deliberately honest: under the current research conditions, VulnPrio performs no better than simpler approaches — and the paper says so explicitly. This “null result” reported with full statistical rigor is the contribution: it establishes a reproducible testing framework that any future system can be compared against, and proves that data-driven superiority claims require real calibrated data — not placeholder weights.

Field Impact:

- First benchmark combining EPSS signals, capacity constraints, KEV-deadline overrides, and hash-chained audit logs in one reproducible pipeline
- 390 hash-chained audit logs, all verifying without error — a tamper-evident decision record mechanism suitable for regulatory environments
- Honest null-result reporting with full statistical apparatus (Wilcoxon + Holm + BCa bootstrap) across 30 seeds and 13 strategies
- Open code and frozen results released for community replication

Technical Abstract:

Vulnerability remediation in large government endpoint fleets is constrained by finite patch capacity, mandatory regulatory timelines, and the daily flood of newly published CVEs. We present **VulnPrio**, a seven-feature linear prioritization framework integrat-

ing EPSS exploit probability, KEV status, CVSS base score, asset criticality, network exposure, urgency, and remediation complexity. The framework is embedded in a five-phase capacity-constrained scheduler with KEV-deadline overrides and append-only SHA-256 hash-chained audit logs. Evaluated against 12 competing strategies across 30 seeds on a fully synthetic fleet dataset, all 13 strategies are *statistically indistinguishable* on the Expected Exploited Host-Days (EHD) metric (inter-strategy spread $< 0.5\%$; all 78 pairwise Wilcoxon+Holm tests: adjusted $p > 0.05$). We report this null result honestly: the contribution is a reproducible, falsifiable, audit-evidence-producing benchmark, not a performance claim. All 390 audit logs hash-verify correctly.

EXHIBIT B

Paper 2: CalibScore

When Calibration Fails: A Failure-Aware Public-Feed Gate for Vulnerability Prioritization Under Sparse Exploit Labels

Harshavardhan Malla — Independent Researcher

Target venues: USENIX CSET (primary); LASER Workshop; ACM DTRAP

Layperson Summary:

Paper 1 uses placeholder (estimated) weights in its scoring formula because no one had measured whether real public data could calibrate them. Paper 2 asks that question directly: can we use publicly available exploit records to find better weights for a realistic government fleet? The answer is no — and this paper explains precisely why, with a formal measurement.

The paper introduces a **failure-aware gate**: a step-by-step procedure for deciding whether you have enough data to calibrate a model before you try. The gate was written down (pre-registered) before any data was collected, so there was no possibility of changing the rules after seeing the results. When applied to a realistic 31-product government fleet, the gate found only 7 confirmed exploitation events over two years — far below the minimum of 20 needed to safely fit a calibration model. The gate said “PIVOT — do not calibrate,” and the paper reports exactly that outcome as its primary finding.

Field Impact:

- First paper to propose a formal “feasibility gate” before attempting public-feed calibration of vulnerability prioritization weights
- Pre-registration of analysis plan (8 stop rules) before any API queries were executed — a clinical-trial-grade methodological standard applied to cybersecurity research
- Quantified data-density boundary: provides a scaling formula ($E[\text{positives}] \approx p \cdot r \cdot m \cdot T$) for practitioners to estimate feasibility before committing to a calibration study
- BCa confidence intervals so wide (Top-10 coverage: [0.00, 0.71]) that they honestly communicate irreducible uncertainty — no false precision

Technical Abstract:

Exploit-occurrence labels from the CISA KEV catalog are sparse in bounded product catalogs. We contribute a pre-registered, multi-stage gate methodology for assessing whether public-feed signals (EPSS v3, NVD, KEV) are dense enough to calibrate vulnerability-prioritization weights without label leakage. The gate comprises: chunked API acquisition with checkpointing; an 18-window multi- t_0 aggregation that maximizes observable distinct positive CVEs; and a three-tier decision rule (PROCEED ≥ 50 , CAUTION 20–49, PIVOT < 20) backed by a pre-registered stop-rule registry. Applied to 2,688 catalog-matched CVEs over the EPSS v3 era (2023-03-07 to 2025-

03-16), we observe only **7 unique positive CVEs** across 18 windows — triggering a gate decision of **PIVOT**: calibration is not attempted. The gate PIVOT is the primary contribution. A pre-registered sensitivity sweep of six design-prior weight vectors produces descriptive statistics with wide BCa CIs, confirming that no vector can be distinguished under this sparsity regime.

EXHIBIT C

Paper 3: HygieneBench

HygieneBench: A Reproducible Synthetic Benchmark for Cyber-Hygiene Anomaly Detection Across Identity, Endpoint, and Patch Telemetry

Harshavardhan Malla — Independent Researcher

Target venues: ACM CCS AISEC Workshop (primary); IEEE S&P Workshop

Layperson Summary:

Good cyber security depends on basic hygiene: making sure old accounts are closed, computer agents are running, patches are applied on time, and data is being collected reliably. When these hygiene checks fail, the conditions exist for attackers to exploit dormant accounts, unmonitored computers, or unpatched vulnerabilities. Detecting hygiene failures automatically is therefore a fundamental security task — but there is no public testing dataset for this problem. Researchers developing AI tools for hygiene monitoring have had no standard way to compare their methods.

HygieneBench fills this gap. It generates realistic (but fully synthetic) organizational data spanning employee accounts, computers, software patches, vulnerability records, and data freshness logs. It includes 12 types of hygiene anomalies and 7 detection tasks, and it tests 8 different detection methods across 5 conditions (including “stale data” conditions that simulate real-world data pipeline failures). The central finding is surprising: **simple rule-based detection** outperforms sophisticated machine learning on 86.2% of tested configurations. Only two tasks (detecting unusual account group changes, and detecting clusters of unpatched critical vulnerabilities) consistently benefit from machine learning.

Field Impact:

- **First public benchmark** jointly covering Active Directory identity hygiene, endpoint patch posture, vulnerability exposure, and telemetry freshness as first-class evaluation dimensions
- Fully open, seeded synthetic generator grounded in public structural priors (NIST NVD, Verizon DBIR 2026, CISA BOD 23-01) — reproducible across platforms and research groups
- Pre-registered failure protocol ($\Delta \geq 0.05$ AP in $\geq 2/3$ seeds) applied rigorously across all 810 evaluation runs — 86.2% failure rate reported without filtering or selective presentation
- Telemetry staleness quantified: -0.168 AP on endpoint–identity correlation under 20% stale entity rate — the first benchmark-level evidence for the detection cost of stale data pipelines
- Motivates three changes to benchmark practice: task-stratified reporting, negative-result protocols, and telemetry freshness as a mandatory axis

Technical Abstract:

Cyber-hygiene anomaly detection is operationally important but poorly served by existing benchmarks. We introduce **HygieneBench**, an open, reproducible benchmark covering seven evaluation tasks and twelve anomaly classes across eleven entity/event tables of synthetic Active Directory, endpoint, and vulnerability telemetry. All data are generated from a seeded synthetic pipeline grounded in public structural priors (NIST NVD, Verizon DBIR 2026, CISA BOD 23-01). An 810-run evaluation of eight detection methods under five telemetry conditions, using a pre-registered failure protocol ($\Delta \geq 0.05$ AP in $\geq 2/3$ seeds), finds that **86.2% of configurations fail to consistently outperform the rule baseline**. ML adds meaningful signal on two of seven tasks: group-membership drift (T2, +0.185 AP, temporal z-score) and patch-vulnerability hygiene (T5, +0.210 AP, OCSVM). Telemetry staleness (C-STALE) consistently degrades performance (-0.168 AP on T3). Generator, datasets, and harness are openly released.

EXHIBIT D

Paper 4: HygienePrio

HygienePrio: Cyber-Hygiene Signal Augmentation for EPSS-Weighted Vulnerability Prioritization

Harshavardhan Malla — Independent Researcher

Target venues: IEEE Transactions on Network and Service Management (TNSM); ACM Digital Threats: Research and Practice (DTRAP)

Layperson Summary:

Paper 1 showed that combining public vulnerability signals (exploit likelihood, CVSS severity, KEV status) did not improve over a simple exploit-likelihood baseline when only CVE-level features were used. Paper 3 showed that host-level hygiene signals — how many patches are overdue, how exposed the machine is through network accounts, how recently data was collected from it — carry genuine discriminative structure in a realistic synthetic fleet. **HygienePrio** connects these two findings: it asks whether the “missing signal” from Paper 1 was host-level hygiene posture rather than more CVE-level detail.

The answer, in the synthetic evaluation, is yes. By building a three-dimensional Hygiene Risk Score (patch debt, Active Directory exposure, telemetry freshness) and combining it with exploit likelihood through a principled weighted formula, HygienePrio achieves substantially higher Precision at the top-50 priority slots than EPSS alone (50.9% vs. 20.2% in the synthetic evaluation; +31 percentage points). Removing the patch-posture component costs the most ground (-20 pp), confirming Paper 3’s finding that patch-vulnerability hygiene is the most discriminative hygiene signal. All results are fully qualified as synthetic-fleet findings; real-fleet validation is explicitly identified as future work.

Field Impact:

- **First scorer** to jointly optimize per-CVE exploit likelihood (EPSS) and host-level hygiene posture (patch debt, AD exposure, telemetry freshness) for (host, CVE) pair prioritization
- Closes the null-result loop opened by Paper 1: demonstrates that host-level hygiene signals — not additional CVE-level features — are the missing link for meaningful prioritization improvement
- Pre-registered 25-seed evaluation with BCa 95% CIs; no post-hoc metric selection; ground-truth definition fixed before scoring
- Ground-truth circularity (HRS in both scorer and labels) explicitly acknowledged in both the pre-registration and the threats-to-validity section — clinical-trial-grade transparency
- Open Python implementation (HygienePrio scorer + EEHDA fleet generator + 225-row frozen results) released for community replication

Technical Abstract:

Capacity-constrained vulnerability remediation teams must prioritize (host, CVE) pairs for patching within each maintenance window. The Exploit Prediction Scoring System (EPSS) is asset-agnostic by design: it scores a CVE, not a host. Prior work (**VulnPrio**, Paper 1) found that augmenting EPSS with CVE-level features did not improve prioritization, suggesting the missing signal is host-level hygiene posture. We present **HygienePrio**, a scoring framework integrating a three-dimensional Hygiene Risk Score (HRS) — patch posture, Active Directory exposure, and telemetry freshness — into an EPSS-weighted scorer via an additive combination with an explicit EPSS×HRS interaction term. In a pre-registered synthetic evaluation across 25 fleet seeds of the EEHDA synthetic fleet, HygienePrio achieves mean Precision@50 of 0.509 compared with EPSS-only’s 0.202 (approximately +31 pp; non-overlapping BCa 95% CIs; synthetic evaluation only). Leave-one-dimension-out ablation confirms patch posture as the dominant HRS component (−20 pp when removed). All results are bounded to the synthetic evaluation context; generalization to real enterprise fleets requires external validation not performed here.

Research Program Coherence

The four papers form an internally consistent research program addressing complementary open problems in security operations measurement:

Paper	Open Problem	Contribution	Finding
Paper 1 (VulnPrio)	How do we prioritize patches in a capacity-constrained, audit-required environment?	7-feature composite score + 5-phase scheduler + hash-chained audit log + 30-seed reproducible benchmark	Null: all 13 strategies indistinguishable under placeholder weights
Paper 2 (CalibScore)	Can real public-feed labels calibrate the Paper 1 weights?	Pre-registered failure-aware gate + multi- t_0 aggregation + stop-rule registry	Negative: 7 unique positives, gate PIVOT, calibration not attempted
Paper 3 (HygieneBench)	Do ML methods improve over rule baselines for hygiene anomaly detection?	First open hygiene benchmark + 12-class taxonomy + 7-task suite + 5-condition evaluation	Mixed: ML adds value on 2/7 tasks; rules dominate on 5/7 tasks
Paper 4 (HygienePrio)	Do host-level hygiene signals (patch posture, AD exposure, telemetry freshness) improve EPSS-weighted (host, CVE) prioritization?	HygienePrio scorer with HRS $\times$ EPSS interaction term + pre-registered 25-seed evaluation + open Python implementation	Positive (synthetic): +31 pp P@50 over EPSS-only; patch posture dominant (noPatch: -20 pp)

Common methodological principles across all four papers:

1. **Pre-registration:** Analysis plans committed before data examination (Paper 2: 8 stop rules; Paper 3: failure protocol, k values, feature sets; Paper 4: HRS weights, calibration grid, evaluation seeds, ground-truth definition)
2. **Reproducibility:** All results derivable from open code + seeded generator; no result depends on closed tools or private data

3. **Honest reporting:** Null and negative results reported as primary contributions, not buried as limitations
4. **Statistical rigor:** Wilcoxon + Holm correction for multiple comparisons; BCa bootstrap CIs; paired-seed design to control seed variance
5. **Ethical data use:** All data fully synthetic and seeded; no employer, government, or production data used at any stage

Evidence of original contribution:

Each paper identifies a genuine gap in the security research literature (acknowledged in Related Work with specific citations), proposes a concrete methodology to address it, executes the methodology with full reproducibility, and reports findings honestly regardless of direction. The research demonstrates:

- Ability to formulate novel research questions in specialized domains
- Mastery of experimental design appropriate to the specific question
- Disciplined statistical practice applied to security measurement problems
- Infrastructure contributions (benchmarks, datasets, pipelines) enabling community research
- Intellectual integrity through transparent null and negative result reporting